

Reference sample — written for the BlueWave Telecom scenario, not your Sankofa Digital case. The structure, length, and writing style are what to copy. The findings are not.

Stage 0 Capstone · Deliverable 4

Judgment essay

Author: Janet Mukami Kariuki **Intern code:** UBI-2026-DEMO **Date completed:** 02 June 2026 **Programme:** Ubuntu Bridge Initiative · Cybersecurity Internship · Cohort 1 **Stage:** 0 · Induction at the Gate

Part A — The ethics call

The prompt

Your manager tells you to close BWT-29222 because the customer behind the affected partner account is one of BlueWave's largest enterprise contracts, and they will not have their account name dragged into a security review.

Response

I would not close BWT-29222. Within the next hour I would document the manager's escalation request inside the ticket itself — verbatim, attributed by timestamp — so the record of the instruction exists regardless of what happens to me next. Within the next four hours I would forward the full evidence chain (the four log entries in `partner-portal.log`, the `vendor-roster.csv:18` termination row, the decoded threat-actor name from `encoded-blob.txt` payload 3) to the Head of Information Security via the secure email channel, with a one-line subject naming the customer and the suspected exposure scope. I would copy the Head of Legal, because customer-data exposure ceases to be a security decision the moment the 72-hour regulator-notification clock under the Data Protection Act 2019 starts.

What I would not do: close the ticket, retitle it to obscure the customer, verbally agree in the standup to "look at it later", or send the evidence chain to anyone outside the security and legal chain. I also would not raise this in the team Slack channel — escalating an ethics issue in a public channel both pre-judges the manager and weakens the formal escalation by making it look reactive.

The ISC2 canon that applies here is **Canon I — Protect society, the common good, necessary public trust and confidence, and the infrastructure**. The compromised account exposed customer billing records of an unknown set of people; the manager's instruction prioritises one party's brand interest above those individuals' right to be told their data may have been touched. Canon I orders these for us: society — which includes the customers — comes before any one party's reputational concern, including BlueWave's. Canon II (act honourably) reinforces this but Canon I is the operative one because the harm is to third parties, not to the profession.

I would escalate next to the Head of Information Security via secure email within 4 hours, copy the Head of Legal, and follow up in person within 24 hours if no acknowledgement arrives. The message would be short: *"I have evidence of customer data exposure tied to BWT-29222 across four log entries between 14 November and 3 December. I have been asked to close the ticket. I have not. I would like fifteen minutes today."*

The personal cost is real. The manager will not forget that I went around them. I will lose informal credit on the next promotion cycle and the next two performance reviews. I am taking that cost because the alternative is letting a notification clock expire on data subjects who never consented to that trade — and I would not be able to defend that choice to myself, to a regulator, or to the canon I signed up to follow.

Part B — The scenario

The prompt

At 04:47 WAT on a Tuesday, you (Tier-1 analyst on the night shift) receive this alert from the SIEM:

>

User `j.kibet` (Operations Manager) just authenticated via publickey from a residential ISP in Nairobi. Her last successful login was 18:30 the previous day from the office. She is not on the on-call roster. Her offboarding ticket BWT-31207 is open with the note "departure date 12 January, key revocation pending".

>

You have 30 minutes before shift handover. What do you do?

Response

I would investigate three things first, in this order. First, the timestamp gap between her last legitimate office session (yesterday 18:30) and the current residential-ISP login (04:47) against her established pattern. `j.kibet`'s normal access in `partner-portal.log` is daytime-only — a 04:47 access is itself the primary anomaly regardless of source IP. Second, the status of BWT-31207 — specifically whether the "key revocation pending" date has elapsed, because Lesson 1 from my D1 row 1 (the `vendor-ace.ke` case) is that offboarding paperwork that does not enforce itself becomes the attack surface. If revocation was scheduled and missed, the key on her workstation is now a valid credential held by whoever last had physical access to the device. Third, the publickey fingerprint on the current session against her registered key in the IdP — if it matches, this is harder to dismiss as a forged session and points back to her actual key being used by someone or something; if it does not match, we have something much closer to a confirmed compromise.

I would escalate at the moment her registered key fingerprint did not match the presented one. That is the specific trigger. The channel would be the on-call security lead's pager, not an email; pager because we have 30 minutes to handover and email is not synchronous at 05:00. The message would name BWT-31207, the time gap (10 hours from her last office session), and the key-mismatch fact.

I would not lock her account in the first ten minutes. The cost of locking a real Operations Manager out at 05:00 because we got nervous is high — she may be travelling on legitimate business using a personal device with her registered key. I would not contact her directly either, because if her account is compromised, the phone call goes to whoever has her phone, which may be the attacker. I would not involve HR at this stage; the case is not yet far enough along to be a personnel issue, and HR escalation creates a paper trail that is hard to retract if this turns out to be benign. I would open a fresh ticket rather than appending to BWT-31207, because appending makes the offboarding paperwork look like the cause when the cause is whoever currently controls her credential.

For the morning shift I would leave this handover note: *"BWT-31207 active. j.kibet authenticated 04:47 from residential ISP; key fingerprint mismatch confirmed against IdP (see BWT-XXXXX I opened). Security on-call paged 05:02. No lock applied, no direct contact. Morning shift: confirm with j.kibet via her registered work number — and only via that number — whether she initiated the 04:47 session. If she did not, lock and escalate to Tier-2 immediately."*

My D1 row 1 informs all of this. Once you have watched one terminated vendor account get used as a working credential for nine days because the SOC trusted the disposition vocabulary over the roster, you stop assuming "pending revocation" means "safe".

Reference sample · BlueWave Telecom scenario · Cohort 1 · Ubuntu Bridge Initiative